

MATRIZ DE ROLES Y PERMISOS

Estructura de Seguridad y Control de Acceso del Sistema — AXON POS

VERSIÓN 2 — CORREGIDA

Este documento reemplaza la versión inicial de la Matriz de Roles y Permisos. Se mantiene la jerarquía y el reparto de responsabilidades ya validado (Propietario > Administrador > Auditor / Bodeguero / Cajero), y se corrigen los puntos de riesgo detectados en la revisión: control sobre la eliminación física de facturas, aprobación de mermas de inventario, límites de descuento, seguridad técnica de acceso y protección de datos personales de clientes.

Resumen de cambios respecto a la versión anterior

- Eliminación física de facturas:** se retira del Propietario. Ningún rol puede borrar una factura desde la operación normal — solo anularla (ver "Reglas transversales").
- Contradicción Propietario/Administrador:** resuelta — ambos quedan bajo la misma regla de "anular, no eliminar".
- Mermas del Bodeguero:** ahora requieren aprobación del Administrador cuando superan un valor configurable (control de doble persona).
- Descuentos del Cajero:** se define un tope configurable por rol (sugerido: Cajero 10%, Administrador sin tope), en vez de "descuentos permitidos" sin límite explícito.
- Seguridad técnica:** se agrega como sección nueva — 2FA, cierre de sesión por inactividad, bloqueo por intentos fallidos.
- Protección de datos personales (Ley 1581 de 2012):** se agrega como sección nueva, aplicable a las exportaciones de reportes del rol Auditor.
- Rol "Gerente de Sucursal":** documentado como consideración futura para cuando el negocio opere multisucursal — no forma parte todavía de la matriz activa.
- 2FA extendido a todos los roles:** ya no se limita a Propietario y Administrador — Cajero y Bodeguero también manejan valor (dinero e inventario), así que quedan bajo la misma exigencia.
- Umbral de mermas con valor de partida:** se define un monto sugerido de arranque (en vez de solo decir "configurable"), y una regla explícita de qué pasa si nadie lo configura — para que el sistema no quede accidentalmente sin control alguno desde el día uno.

Jerarquía de roles



1. PROPIETARIO (Super Administrador)

Nivel de jerarquía máximo. Control sobre todos los módulos, reportes y configuraciones del sistema — sujeto a las reglas transversales de auditoría e integridad de facturación.

PERMISOS ASIGNADOS

- Configuración general del sistema (datos de la empresa, resolución DIAN, impuestos).
- Creación, edición y desactivación de usuarios y roles.
- Acceso a reportes financieros avanzados (pérdidas y ganancias, rentabilidad, flujo de caja).
- **Anulación** de facturas, gastos y productos **CORREGIDO**
- Gestión multicaja y multisucursal (si aplica).
- Acceso de **consulta** al log/historial de auditoría, para supervisar las acciones de todos los empleados.

RESTRICCIONES

- **No puede eliminar (borrar físicamente) facturas** — solo anularlas, igual que el Administrador. El borrado físico solo procede por un procedimiento excepcional y separado, con doble confirmación y participación de soporte técnico. **CORREGIDO**
- **No puede alterar ni borrar el historial de auditoría** — toda acción del Propietario también queda registrada ahí, sin excepción. **CORREGIDO**

2. ADMINISTRADOR

Responsable de la operación diaria del establecimiento. Supervisa el flujo comercial, el personal y el inventario.

PERMISOS ASIGNADOS

- Gestión completa del catálogo de productos, precios y categorías.
- Supervisión de inventario y **aprobación de mermas** reportadas por el Bodeguero que superen el umbral configurado. **NUEVO**
- Creación de usuarios de menor rango (Cajero, Bodeguero, Auditor).
- Acceso a reportes operativos (ventas del día, cierres de caja, productos más vendidos).
- Gestión de devoluciones, garantías y notas crédito.
- Apertura, cierre y arqueo de todas las cajas.
- Define el tope de descuento permitido para el rol Cajero. **NUEVO**

RESTRICCIONES

- No puede eliminar usuarios con rol de "Propietario".
- No puede alterar la configuración fiscal ni las resoluciones de facturación.
- No puede eliminar facturas de forma permanente — solo anularlas (misma regla que el Propietario, ya sin contradicción). **CORREGIDO**
- No puede borrar ni alterar el historial de auditoría.

3. AUDITOR (Contable / Supervisor)

Rol de solo lectura para contadores o revisores fiscales. Su objetivo es el análisis de datos sin alterar la información.

PERMISOS ASIGNADOS

- Visualización y exportación de reportes de ventas, compras e impuestos (IVA, Impoconsumo).
- Revisión de cuadros y cierres de caja (Reportes Z).
- Consulta de historial de movimientos de inventario (Kardex).
- Revisión de comprobantes de ingreso y egreso.
- Lectura del registro de eventos del sistema (auditoría de acciones).
- Toda exportación de reportes con datos personales de clientes queda sujeta a las reglas de protección de datos (ver "Reglas transversales"). **NUEVO**

RESTRICCIONES

- **Rol de solo lectura:** no puede facturar ni realizar cobros.
- No puede modificar precios, costos, ni existencias de inventario.
- No puede crear, modificar ni eliminar usuarios.
- No puede alterar configuraciones del sistema.
- No puede exportar datos personales de clientes sin que quede registrado en el log de auditoría quién exportó qué y cuándo. **NUEVO**

4. BODEGUERO (Inventario)

Encargado de la logística, almacenamiento y control físico de la mercancía.

PERMISOS ASIGNADOS

- Recepción de mercancía y registro de facturas de compra/proveedores.
- Ingreso y salida manual de inventario por mermas, traslados o averías — **las mermas que superen el valor configurado por el Administrador quedan pendientes de su aprobación** antes de aplicarse. **CORREGIDO**
- Consulta del catálogo de productos y niveles de stock.
- Generación e impresión de etiquetas de códigos de barras.
- Registro de toma física de inventario.

RESTRICCIONES

- No tiene acceso al módulo de Facturación / POS.
- No puede ver reportes de ingresos, ventas diarias o rentabilidad.
- No tiene acceso al manejo de efectivo, cajas ni medios de pago.
- No puede modificar los precios de venta al público.
- **No puede aprobar sus propias mermas** cuando superan el umbral — la aprobación siempre la hace un rol distinto (Administrador o superior). **NUEVO**

5. CAJERO

Personal en punto de pago. Rol enfocado exclusivamente en la atención al cliente y registro de transacciones de venta.

PERMISOS ASIGNADOS

- Apertura y cierre de su turno/caja asignada.
- Creación de facturas POS, recibos y cotizaciones.
- Recepción de múltiples medios de pago (efectivo, tarjetas, transferencias).
- Consulta rápida de precios y existencias de productos.
- Aplicación de descuentos **dentro del tope configurado para su rol** (sugerido: máx. 10%) o registro de clientes fidelizados. **CORREGIDO**

RESTRICCIONES

- No puede anular facturas pasadas ni hacer devoluciones (requiere autorización de Administrador).
- No puede modificar el inventario de forma manual (entradas/salidas).
- No tiene acceso a configuraciones, creación de productos ni modificación de precios base.
- Solo puede ver el reporte de ventas de su propio turno (no reportes globales).
- **No puede aplicar un descuento mayor al tope configurado** sin autorización de un Administrador. **NUEVO**

Reglas transversales

Aplican sobre todos los roles anteriores, sin importar el nivel jerárquico. Corrigen los puntos de riesgo identificados en la versión anterior del documento.

A. Anulación vs. eliminación de facturas

Ningún rol —ni siquiera el Propietario— puede eliminar (borrar físicamente) una factura desde la operación normal del sistema. Toda factura solo se **anula** (queda visible, marcada como anulada, con motivo y usuario registrados). El borrado físico de un registro de facturación es una operación excepcional, fuera del flujo normal de roles, que exige doble confirmación y la participación de soporte técnico, y que en sí misma queda registrada en el log de auditoría.

Consistente con el tratamiento de facturación electrónica en Colombia (DIAN): un documento fiscal se anula, no se hace desaparecer.

B. Aprobación de mermas (control de doble persona)

Toda merma registrada por el Bodeguero que supere un umbral configurable (definido por el Administrador, en pesos o en % del costo del producto) queda en estado **"pendiente de aprobación"** hasta que un Administrador (o rol superior) la revise y apruebe. Por ejemplo, con el umbral en \$50.000: una pérdida de \$30.000 se registra normal, sin intervención; una de \$200.000 queda pendiente hasta que el Administrador la revise. Esto evita que una salida de inventario reportada como merma sea en realidad una sustracción no autorizada ("robo hormiga") sin que nadie más la revise.

Valor de partida sugerido: \$50.000 COP por movimiento individual (ajustable por el Administrador según el tamaño del inventario del negocio). **CORREGIDO**

Regla de default seguro: mientras el Administrador no configure explícitamente este umbral, el sistema debe asumirlo en **\$0** — es decir, toda merma requiere aprobación hasta que alguien decida subir el límite. La ausencia de configuración nunca debe interpretarse como "sin límite": eso dejaría abierta exactamente la puerta que esta regla busca cerrar. **CORREGIDO**

C. Tope de descuentos configurable por rol

El sistema permite configurar, por rol, un porcentaje máximo de descuento aplicable sin autorización adicional. Punto de partida sugerido:

- Cajero: hasta 10%.
- Administrador: sin tope, o un tope superior configurable.
- Propietario: sin tope.

Un descuento que supere el tope del rol requiere la autorización (PIN/clave) de un rol con tope superior.

D. Seguridad técnica **NUEVO**

- **Autenticación de dos factores (2FA) obligatoria para TODOS los roles** — Cajero y Bodeguero incluidos, no solo Propietario y Administrador: ambos manejan valor real (dinero e inventario) y son un objetivo igual de válido para un acceso indebido. **CORREGIDO**
- Cierre de sesión automático por inactividad (tiempo configurable).
- Bloqueo temporal de la cuenta tras N intentos fallidos de inicio de sesión consecutivos, con cada intento (exitoso o fallido) registrado en el historial de seguridad.
- Historial de sesiones activas por usuario, con opción de cierre remoto.

E. Protección de datos personales — Ley 1581 de 2012 (Habeas Data) NUEVO

Cualquier reporte exportado (por el rol Auditor u otro rol con permiso de exportación) que contenga datos personales de clientes (nombre, documento, teléfono, correo, dirección) debe:

- Dejar registro en el log de auditoría de quién exportó el reporte, cuándo, y qué rango de datos incluyó.
- Estar disponible solo para roles con una finalidad legítima definida — no exportación libre para cualquier rol con acceso de lectura.
- Permitir enmascarar o anonimizar parcialmente datos sensibles en reportes agregados que no necesiten el dato completo (ej. mostrar solo los últimos 4 dígitos de un documento).

Recomendación de cumplimiento normativo colombiano; la implementación exacta debe validarse con asesoría legal antes de considerarse completa.

Consideración futura: rol "Gerente de Sucursal"

Si el negocio crece a operar más de una sucursal, se sugiere incorporar un rol intermedio entre Administrador y Propietario: permisos equivalentes a Administrador, pero acotados a su propia sucursal (sin visibilidad ni gestión de otras sucursales), y sin acceso a la configuración fiscal global del negocio.

Este rol NO forma parte todavía de la matriz activa — queda documentado como punto pendiente de definición, a incorporar cuando el negocio efectivamente opere multisucursal.